



ISO22301 Toolkit Implementation Guide

Contents

1	Toolkit support and services	4
1.1	Email support	4
1.2	Toolkit updates	4
1.3	Review of completed documents.....	4
1.4	Exclusive access to customer discussion group	4
1.5	ISO22301 Services	4
1.5.1	Implementation Consultancy	5
1.5.2	Internal audits	5
2	Introduction	6
2.1	The ISO22301 standard	6
2.2	The CertiKit ISO22301 Toolkit	9
2.3	If yours is a small organization	11
2.4	Where to start.....	11
2.5	A suggested project plan	14
2.6	How this guide is structured	16
3	Using the CertiKit ISO22301 Toolkit.....	18
3.1	Section 0: Introduction.....	18
3.2	Section 1: Scope	18
3.3	Section 2: Normative references	19
3.4	Section 3: Terms and definitions	19
3.5	Section 4: Context of the organization	20
3.6	Section 5: Leadership	21
3.7	Section 6: Planning.....	22
3.8	Section 7: Support.....	22
3.9	Section 8: Operation	23
3.9.1	Business impact analysis	25
3.9.2	Risk assessment.....	26
3.9.3	Business continuity strategies and solutions.....	27
3.9.4	Business continuity plans and procedures.....	28
3.9.5	Exercise programme	29
3.9.6	Evaluation of business continuity documentation and capabilities.....	29
3.10	Section 9: Performance evaluation	29
3.10.1	Monitoring, measurement, analysis and evaluation.....	30
3.10.2	Internal audit	30
3.10.3	Management review	31
3.11	Section 10: Improvement.....	31
4	Advice for the audit	32

4.1 Choosing an auditor 32

4.1.1 Self-certification32

4.1.2 Third-party certification32

4.1.3 Other IAF members33

4.1.4 Choosing between accredited RCBs34

4.2 Are we ready for the audit? 35

4.3 Preparing for audit day 36

4.4 At the audit 36

4.5 After the audit 37

5 Conclusion 39

Figures

Figure 1: Overall BCMS implementation order 16

1 Toolkit support and services

The CertiKit ISO22301 toolkit includes 70+ templates and guides to allow your organization to align to the requirements of the standard and comes with the following support.

1.1 Email support

We understand you may need some extra support and advice, so this is why we offer unlimited email support for as long as you need after buying this toolkit.

1.2 Toolkit updates

This toolkit includes lifetime updates, which means whenever there is a revised toolkit (usually when a new version of the standard is released), you will receive an email notification and the new toolkit will be available to download.

1.3 Review of completed documents

If you need that extra piece of mind once you have completed your documentation, our experts will review up to three of your documents to check everything is in order and complies to the ISO22301 standard.

1.4 Exclusive access to customer discussion group

Complying to the ISO22301 standard can be a daunting journey, which is why we offer a range of support channels to suit you. This includes our social media discussion group.

1.5 ISO22301 Services

Whilst our ISO22301 toolkit has all the documentation and guidance you'll need to implement a BCMS and achieve certification to the standard, we do offer both consultancy and internal auditing services to speed up the process and offer expertise in key areas.

1.5.1 Implementation Consultancy

Our ISO consultants have successfully helped many organizations prepare for their certification audits. Our flexible consultancy options are available to assist your project however you need.

Our clients use our consultancy in the following ways:

- Ad-hoc hours or days to cover a few specific areas
- Weekly or monthly meetings to keep the project moving forward
- Documentation writing to speed up the process
- A fully managed project to get you to certification fast

We're often asked to assist with the key stages such as Scope, Gap Analysis, Risk Assessment and even integrating multiple management systems. We can create a phased proposal for you to choose what meets your timescale and budget constraints. [Find out more about our consultancy services here.](#)

1.5.2 Internal audits

In order to meet the requirements of clause 9.2 of the ISO22301 standard certification audit you need to have evidence of a completed internal audit of your management system by a qualified auditor. If you haven't got an internal auditor within your organization or resource to train one, then outsourcing your internal audit is the best option.

From full pre-certification audits to ongoing surveillance audits, our qualified auditors can help you achieve the requirements of the standard. [Find out more about our internal auditing services here.](#)

Note, CertiKit are not a Registered Certification Body and cannot provide you with a formal management system certification. All services are conducted remotely via MS Teams by our consultants in the UK time zone and are only available to organizations +/- two hours of the UK time zone.

2 Introduction

The Covid-19 pandemic in 2020 brought business continuity into sharp focus as a business issue. An unprecedented economic shutdown combined with massive public health challenges left many organizations struggling to cope with the impact of such a major event. Adding the ongoing issue of climate change to such events creates a good likelihood that the future is going to be full of uncertainty. So, it might be reasonable to expect that business continuity planning will be firmly on the agenda of world commerce and industry from now on. And one of the most effective ways of addressing this issue is to adopt a framework such as the ISO22301 standard.

This concise guide takes you through the process of implementing the ISO22301 international standard for business continuity. It provides a recommended route to certification against the standard starting from a position where very little is in place. Of course, every organization is different and there are many valid ways to embed the discipline of business continuity. The best way for you may well depend upon a number of factors, including:

- The size of your organization
- The country or countries in which you operate
- The culture your organization has adopted
- The industry you operate within
- The resources you have at your disposal

So, view this guide simply as a pointer to where you could start and a broad indication of the order you could do things in. There is no single “right way” to implement business continuity; the important thing is that you end up with a Business Continuity Management System (BCMS) that is relevant and appropriate for your specific organization’s needs. One that goes at least partway to preparing for the impact of the next major event, whether that’s another pandemic or localised flooding.

Good luck.

2.1 The ISO22301 standard

The ISO22301 international standard for “Business continuity management systems – Requirements” was first published by the ISO in 2012 and is based upon the earlier British standard BS25999-2. The standard was then revised in 2019, although with very few significant changes, the emphasis being more on structure alignment with other standards, and clarification of wording.

ISO22301 specifies the requirements that your BCMS will need to meet in order for your organization to become certified to the standard. The requirements in ISO22301 are supplemented by guidance contained in ISO22313 which was also first published in 2012 and has been updated in 2020. ISO22313 is well worth reading as it fills in some of the gaps

in understanding how the requirements in ISO22301 should be met and gives more clues about what the auditor may be looking for.

There are certain other documents published within the ISO 22300 series and many of them provide useful supporting information for organizations going for ISO 22301 certification (or simply using it for guidance). Some of the common ones are:

- ISO22313 – Guidance on the use of ISO 22301
- ISO 22316 – Organizational resilience – Principles and attributes
- PD ISO/TS 22318 – Guidelines for supply chain continuity
- ISO 22319 – Guidelines for planning the involvement of spontaneous volunteers
- ISO 22320 – Guidelines for incident management
- PD ISO/TS 22330 – Guidelines for people aspects of business continuity
- ISO 22395 – Guidelines for supporting vulnerable persons in an emergency

It's worth pointing out that, although useful, none of these are required reading for certification to the ISO 22301 standard so if you are limited in time and budget, just a copy of ISO 22301 itself will suffice (although if you haven't purchased the standard yet, we would recommend you look at our Enhanced Gap Assessment Tool as an alternative as it includes all of the requirements in the standard but in a more useful format).

There's no obligation to go for certification to ISO22301 and many organizations choose to simply use the standard as a set of good practice principles to guide them along the way to protecting their business.

One subject worth mentioning is that of something the ISO calls "Annex SL". This is a very obscure name for a concept that represents a big change in ISO management system standards, starting with ISO22301. There are a number of ISO standards that involve operating a "management system" to address the specific subject of the standard. Some of the main examples are:

- ISO9001: Quality management
- ISO14001: Environmental management
- ISO/IEC 27001: Information security management
- ISO/IEC 20000: IT service management

Traditionally, all of these standards have had a slightly different way of implementing and running a management system and the wording of the standards has varied sometimes quite significantly. This is ok until an organization decides to try to run a single management system across multiple standards, for example ISO9001 and ISO/IEC 27001. Then it becomes difficult for the organization to marry up differing ways of doing the same thing and it makes the auditors' job harder (and longer and more expensive) too.

So, to get around this problem of "multiple management systems" the ISO decided to standardise the wording of the management system parts of the standards. They produced a long document with numerous appendices, one of which was "Annex SL" containing a first draft of the standard wording. Over time the ISO is now phasing in this common "Annex SL" wording and all new standards or new versions of existing standards will have it. As it

happens, ISO22301 was the first to adopt this new layout and so may be called the first “Annex SL” standard. Since 2012 many other standards have been revised including ISO/IEC 27001 (Information security), ISO9001 (Quality management) and ISO14001 (Environmental management).

The good news for an organization implementing a BCMS based on ISO22301 is that they will by default be putting in place an “Annex SL” management system. This will make it much easier for them to implement other standards such as ISO9001 at a later date.

The ISO22301 standard consists of a number of major headings which will be common across other standards (because they are the “Annex SL” headings) and which are:

0. Introduction
1. Scope
2. Normative references
3. Terms and definitions
4. Context of the organization
5. Leadership
6. Planning
7. Support
8. Operation
9. Performance evaluation
10. Improvement

Sections 0 to 3 don’t contain any requirements and so an organization wouldn’t be audited against those. They are worth a read however as they provide some useful background to what the standard is about and how it should be interpreted.

Sections 4 to 10 set out the requirements of the standard. Requirements are often referred to as the “shalls” of the standard because that is the word usually used by ISO to show that what is being stated is compulsory if an organization is to be compliant. So, the (internal and external) auditing process is basically an exercise to check whether all of the requirements are being met by the organization. Requirements are not optional and if they are not being met then a “non-conformity” will be raised by the auditor and the organization will need to address it to gain or keep their certification to the standard (see the section on auditing later in this guide).

In order to show that the requirements are being met the auditor will need to see some evidence. This can take many forms and until recently was defined as a combination of “documents” (evidence of intention such as policies, processes and procedures) and “records” (evidence that something has been done). In the new versions of the standards the term “documented information” is generally used instead to cover anything that is recorded (the official definition from section 3 of ISO22301 is “information required to be controlled and maintained by an organization and the medium on which it is contained”). But the point is you need to have something to show the auditor.

This is often a major culture change in many organizations. Just doing something is no longer enough; you must be able to prove that you did something. This means keeping

records in areas you maybe don't keep records at the moment, a good example often being meeting minutes. Meetings happen and things are discussed, and decisions are made but the auditor won't just accept your word for it. The auditor will want to see the minutes. Other examples could be training records – who was trained to do what and when? Business continuity tests – what was tested, by whom, when and what was the outcome?

All of this sounds rather onerous, a lot of hassle. True, it can mean more work at least in the short term. But doing business continuity according to the ISO22301 standard is about doing it right. You will be taking advantage of the knowledge of a wide variety of experienced people who have come together to define the best way to create a BCMS that works; people from all over the world in a wide variety of industries and organizations large and small.

From our experience what often happens during the process of implementing an international standard such as ISO22301 is that initially you will put things in place because the standard says you will. Some of the requirements may seem unnecessary or over the top. But gradually you will start to see why they are included and the difference it makes to your organization. After a period of time you will begin to implement procedures and methods that go further than the requirements of the standard because you can see that they would be useful and will provide better protection for your organization. You'll start to see that it's about becoming more proactive in everything you do and in the long term this reduces the number of reactive activities necessary. In simple terms, you'll start to "get it" (but be patient, it can take a while!).

But in the meantime, you'll need to create some of that "documented information". And that's where the CertiKit ISO22301 Toolkit comes in....

2.2 The CertiKit ISO22301 Toolkit

When looking at business continuity the emphasis is usually on "The Plan". This is the document (or documents) that will tell everyone what to do in an emergency, how to handle a crisis and keep the business running. And it's right that this should be the main focus; it is, after all, the main deliverable of the whole business continuity idea.

In a perfect world we would just create The Plan, based on our perfect knowledge of the business and nothing would ever change. The Plan would be accurate at all times, never need improving and everyone would know how to use it.

But we live in a far from perfect world where things can and do change on a regular basis, we don't know everything about the business, people come and go from the organization and our definition of what's important moves all the time.

So, the ISO22301 standard proposes that we don't just need a plan; we need a Business Continuity Management System or BCMS. The function of the BCMS is to wrap itself around the plan and ensure (among other things) that:

1. The plan is based on the right information about the business (Business Impact Analysis)
2. We have a good idea of what we need to plan for (Risk assessment)
3. The plan works (Exercising and testing)
4. Everybody knows about the plan and how to use it (Awareness and training)
5. We update the plan when things change around it (Management review)
6. The plan gets better over time (Continual improvement)

The CertiKit ISO22301 Toolkit (referred to within this document simply as the “Toolkit”) provides not only the plan, but also a large part of the BCMS that supports it. So, within your Toolkit you will have an array of useful documents which provide a starting point for all of the different areas of the standard. The documents are in Microsoft Office 2010® format and consist of Word documents, Excel workbooks, PowerPoint presentations and Project plans.

Each document is located within a folder structure that maps onto the various sections of the standard and is placed under the section that is most relevant to its content. Some documents are relevant to multiple sections of the standard and are placed in the one of greatest relevance.

A document reference naming convention is used throughout the Toolkit which is described in *Procedure for the Control of Documented Information*. This includes a reference to the section number of the ISO22301 standard in which the document is stored.

The standard doesn’t require that you use a specific naming convention so feel free to change the names of documents within the Toolkit if you need to. An example of this is many organizations refer to business continuity plans as disruption plans. As long as everyone involved with the business continuity of the organization is aware of the document terminology used, an auditor will be happy.

The documents within the toolkit themselves have a common layout and look and feel and adopt the same conventions for attributes such as page widths, fonts, headings, version information, headers and footers. Custom fields are used for the common items of information that need to be tailored such as [Organization Name] and these need to be changed in each document.

Every document starts with an “Implementation Guidance” section which describes its purpose, the specific areas of the ISO22301 standard it is relevant to, general guidance about completing and reviewing it and some legal wording about licensing etc. Once read, this section may be removed from the final version of the document.

The layout and headings of each document have been designed to guide you towards meeting the requirements of the standard and example content has been provided to illustrate the type of information that should be given in the relevant place. This content is based upon an understanding of what a “typical” organization might want to say but it is very likely that your organization will vary from this profile in many ways so you will need to think carefully about what content to keep and what to change. The key to using the Toolkit successfully is to review and update each document in the context of your specific

organization. Don't accept the contents without reading them and thinking about whether they meet your needs – does the document say what you want it to say, or do you need to change various aspects to make it match the way you do things? This is particularly relevant for policies and processes where there is no “right” answer. The function of the document content is help you to assess what's right for you so use due care when considering it. Where the content is very likely to need to be amended, we have highlighted these sections but be aware that other non-highlighted sections may also need to be updated for your organization.

2.3 If yours is a small organization

The CertiKit ISO22301 Toolkit has been deliberately designed to be flexible and easy to adapt to your needs. The standard itself doesn't dictate any specific structure of documentation so you're free to do whatever makes sense for you as long as the requirements are met. Some smaller organizations decide to merge some of the supplied documents together so that the total number of documents in the BCMS is reduced. This makes sense if the number of people involved is small and approval cycles are short. To help with this process, you may like to consider the following suggestions for documents that could be merged together:

A Business Continuity Manual could also incorporate:

- *Roles Responsibilities and Authorities*
- *Procedure for the Control of Documented Information*
- *Procedure for Internal Audits*
- *Procedure for Management Reviews*
- *Procedure for the Management of Nonconformity*

It's up to each small organization to decide if this approach would be right for them; inevitably there are pros and cons of having more or fewer documents and some form of compromise solution based on our suggestions might also be appropriate.

2.4 Where to start

Relevant Toolkit documents:

- *ISO22301 Toolkit Index*
- *ISO22301 Gap Assessment Tool*
- *ISO22301 Assessment Evidence*
- *ISO22301 Benefits Presentation*
- *Certification Readiness Checklist*
- *ISO22301 In Simple English*

And an additional option:

- *ISO22301 Enhanced Gap Assessment Tool*

Before embarking on a project to achieve compliance (and possibly certification) to the ISO22301 standard it is very important to secure the commitment of top management to the idea. This is probably the single most significant factor in whether such a project (and the ongoing operation of the BCMS afterwards) will be successful. Indeed, “Leadership” has its own section within the standard and without it there is a danger that the BCMS will not be taken seriously by the rest of the organization and the resources necessary to make it work may not be available.

The first questions top management are likely to ask about a proposal to become certified to the ISO22301 standard are probably:

- What are the benefits – why should we do it?
- How much will it cost?
- How long will it take?
- What are the potential disruptions to the organization?

Our recommendation is to conduct a business impact analysis (BIA) first; this would provide the information on the potential disruptions, the resources required both materially and fiscally and give a better idea of the amount of work that would be required to populate the business continuity plans.

In order to help answer these questions the CertiKit ISO22301 Toolkit provides a number of resources.

The *Business Impact Analysis Process* and *Business Impact Analysis Report* in section 8 – Operations folder of the toolkit provide the information needed to conduct a BIA. They include the resources required, the information needed and how it is assessed and the potential impact to the continuity of ‘business as normal’ due to specific disruptions. This will provide the information used to populate the BIA Report. This is a powerful document which clearly lays out for top management the potential loss to the organization of money, potential reputation, and customers caused by identified disruption scenarios. Conducted prior to the gap analysis, it will help build the business case for the BCMS.

The *ISO22301 Gap Assessment Tool* is an Excel workbook that provides a way of quantifying to what extent your organization currently meets the requirements contained within the standard. By performing this gap assessment, you will gain a better appreciation of how much work may be involved in getting to a point where a certification audit is possible.

The Tool breaks the standard down by area and section and a series of key questions are asked in order to assess how close to meeting the standard your organization is. The questions are designed to address the main requirements of the standard and a positive answer means that you are likely to be conformant. It includes a dashboard of tables and

charts showing an analysis of where your organization meets the standard and where there is still work to do.

However, if you would prefer to have all of the exact requirements of the standard laid out for you then we provide a further, enhanced tool which is a chargeable extra to the Toolkit and available via the CertiKit website. We are able to provide this because we have a licensing agreement with the ISO, via BSI, to include the full contents of the requirements of the standard (for which CertiKit pays a license fee). The *ISO22301 Enhanced Gap Assessment Tool* goes several steps further than the default gap assessment tool by breaking down the text of the ISO 22301 standard itself into individual requirements (with the full text of each requirement) and providing a more detailed analysis of your conformance. It can also be used to allocate actions against individual requirements.

The key to making this gap assessment as accurate as possible is to get the right people involved so that you have a full understanding of what is already in place. The *ISO22301 Gap Assessment Tool* will provide hard figures on how compliant you currently are by area of the standard and will even show you the position on a range of charts to share with top management. It's a good idea to repeat the exercise on a regular basis during your project in order to assess your level of progress from the original starting point.

The accompanying workbooks *ISO22301 Toolkit Index* and *ISO22301 Assessment Evidence* show you how the various documents in the Toolkit map onto the requirements of the standard and what other evidence may be appropriate to show compliance. This may help when deciding whether a requirement is met or not.

Having gained an accurate view of where you are against the standard at the moment, you are then armed with the relevant information to assess how much effort and time will be required to achieve certification. This may be used as part of a presentation to top management about the proposal and a template *ISO22301 Benefits Presentation* is provided in the Toolkit for this purpose. Note that budgetary proposals should include the costs of running the BCMS on an ongoing basis as well as the costs of putting it in place.

As part of your business case, you may also need to obtain costs from one or more external auditing bodies for a Stage One and Stage Two review and ongoing surveillance audits (see later section about external auditing). To save money, you don't want to go to your Stage One audit without knowing you're ready, so we provide a *Certification Readiness Checklist* to tell you if you have the main building blocks in place.

Lastly, it's worth mentioning *ISO22301 In Simple English* which is our attempt to translate the ISO-speak of ISO22301 into something resembling English. Don't rely on this as your copy of the standard itself, but it can help to understand what ISO actually means in the more cryptic places.

2.5 A suggested project plan

Relevant Toolkit documents:

- *ISO22301 Project Plan (Excel and Project versions)*
- *Project Kick-off Meeting Agenda*
- *BCMS Project Initiation Document*
- *ISO22301 Progress Report*

Having secured top management commitment, you will now need to plan the implementation of your BCMS. Even if you're not using a formal project management method such as PRINCE2® we would still recommend that you do the bare essentials of defining, planning and tracking the implementation effort as a specific project. The Toolkit includes an outline agenda for a project kick-off meeting, which all relevant parties should attend.

We have provided a template *Project Initiation Document* (or PID) which prompts you to define what you're trying to achieve, who is involved, timescales, budget, progress reporting etc. so that everyone is clear from the outset about the scope and management of the project. This is also useful towards the end of the project when you come to review whether the project was a success. Having written the PID, try to ensure it is formally signed off by top management and that copies of it are made available to everyone involved in the project so that a common understanding exists in all areas.

The CertiKit ISO22301 Toolkit provides a Microsoft Project® plan as a starting point for your project. This is fairly high level as the detail will be specific to your organization, but it gives a good indication as to the rough order that the project should be approached in. It's fair to say that in general if you implement your BCMS in the order of the ISO22301 standard from section 4 to section 10 you won't go far wrong. However, as mentioned earlier, you may want to consider conducting the BIA first then proceeding with the project plan. This isn't necessarily true of some of the other management system standards we have mentioned such as ISO/IEC 20000 but for ISO22301, because it includes much of the business continuity content within section 8 (Operation), it actually flows quite well.

Because not everybody uses Microsoft Project, we also provide an Excel version of the project plan which now includes a Gantt chart, basic project budgets and a handy dashboard.

The main steps along the way to certification are described in more detail later in this guide and there are some parts that need to be done in a certain order otherwise the right information won't be available in later steps. An example is that you need to complete your business impact analysis (BIA) before carrying out your risk assessment because otherwise you won't have enough information to assess the severity of each risk properly.

A simple twelve-step sequence for the route to certification is shown in figure 1 below. As suggested, this effectively steps through the standard in order although it starts with the BIA and the foundation for the project (and for the ongoing BCMS) which is obtaining management commitment.

Once a project manager has been appointed, the project has been planned and started, it's a good idea to keep an eye on the gap assessment you carried out earlier and update it as you continue your journey towards certification. This updated measurement of your closeness to complete conformity with the standard can be included as part of your regular progress/highlight reports and the CertiKit ISO22301 Toolkit includes a template for such reports.

The timing of when to go for certification really depends upon your degree of urgency (for example you may need evidence of certification for a commercial bid or tender) and how ready you believe the organization to be. Certainly, you will need to be able to show that all areas of the BCMS have been subject to internal audit before asking your external auditing body to carry out the stage two (certification) assessment. But you don't need to wait until you're "perfect", particularly as the certification audit will almost certainly throw up things you hadn't thought of or hadn't previously regarded as important.

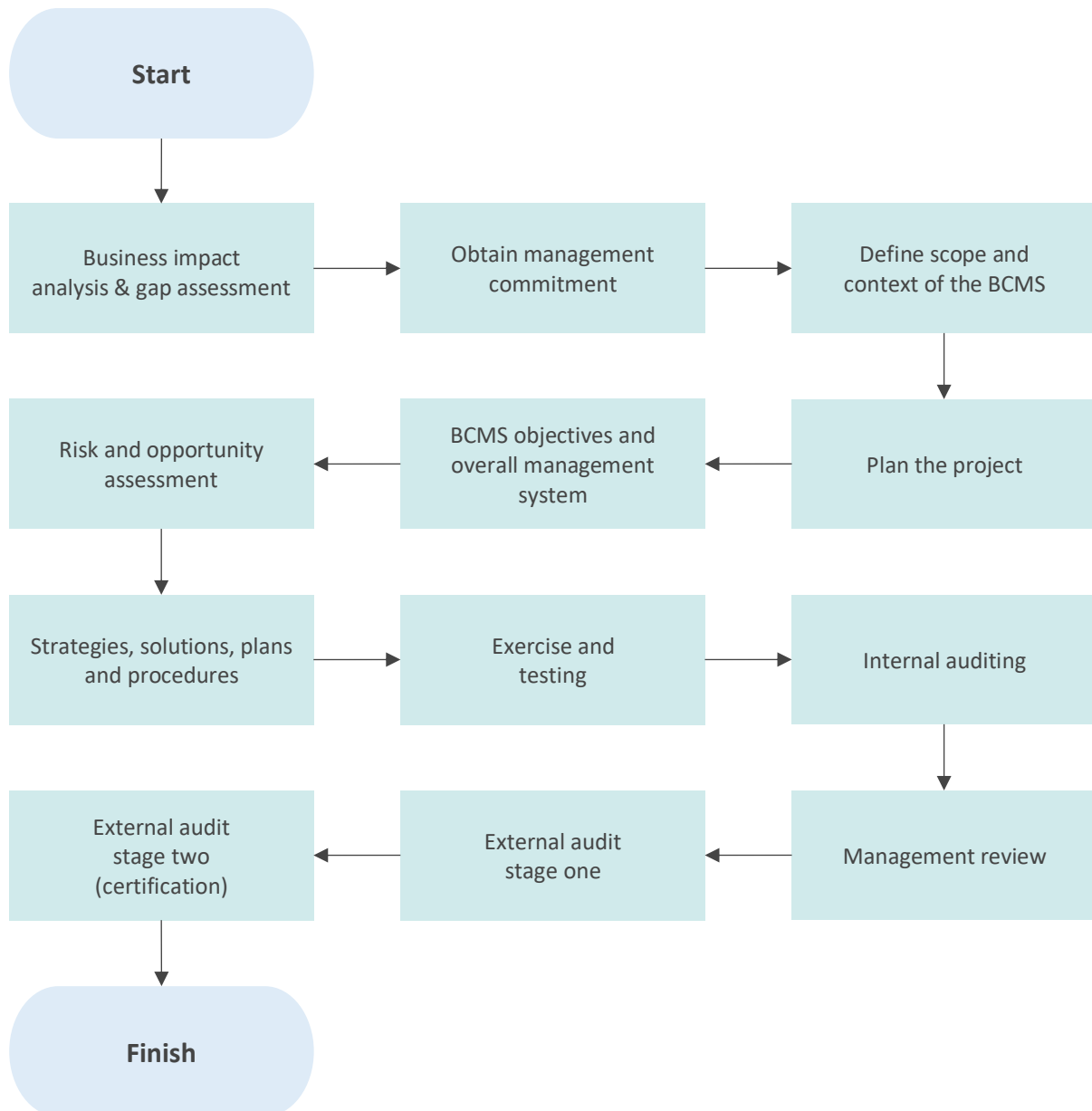


Figure 1: Overall BCMS implementation order

2.6 How this guide is structured

The remainder of this guide will take you through the sections of the ISO22301 standard one by one, explaining what you may need to do in each area and showing how the various items in the CertiKit ISO22301 Toolkit will help you to meet the requirements quickly and effectively.

As we've said earlier, regard this guide as helpful advice rather than as a detailed set of instructions to be followed without thought; every organization is different and the idea of a BCMS is that it moulds itself over time to fit your specific needs and priorities.

We also appreciate that you may be limited for time and so we have kept the guidance short and to the point, covering only what you need to know to achieve compliance and hopefully certification. There are many great books available on the subject of business continuity and we recommend that, if you have time, you invest in a few and supplement your knowledge as much as possible.

3 Using the CertiKit ISO22301 Toolkit

3.1 Section 0: Introduction

Relevant Toolkit documents:

- *None*

The introduction to the standard is worth reading, if only once. It gives a good summary of what the ISO sees as the key components of a BCMS; this is relevant and important when understanding where the auditor is coming from in discussing what might be called the “spirit” of the BCMS. The detail in other sections of the standard should be seen in the context of these overall principles and it’s important not to lose sight of that when all attention is focussed on the exact wording of a requirement.

The Plan-Do-Check-Act (PDCA) model is described more for backwards compatibility reasons than because it’s important in ISO22301, as the standard doesn’t refer to it again, so don’t worry too much if these sections don’t make much sense to you.

An explanation of the specific meaning of a number of key words used in all such standards is given:

- “Shall” means you must
- “Should” means we think you ought to, but you don’t strictly have to
- “May” means you can if you want to
- “Can” means it’s possible, but we’re not saying you should, or you shouldn’t

Obviously the important one in the above list is “shall” as where this is used it means it’s a requirement you will be expected to comply with in your BCMS.

There are no requirements to be met in this section.

3.2 Section 1: Scope

Relevant Toolkit documents:

- *None*

This section refers to the scope of the standard rather than the scope of your BCMS. It explains the fact that the standard is a “one size fits all” document which is intended to apply across business sectors, countries and organization sizes and can be used for a variety of purposes.

There are no requirements to be met in this section.

3.3 Section 2: Normative references

Relevant Toolkit documents:

- *None*

Some standards are supported by other documents which provide further information and are very useful if not essential in using the standard itself. For ISO22301 there is one, which is ISO22300 which sets out the relevant vocabulary. We would however suggest that you may also like to refer to ISO22313 as it provides further guidance on the interpretation and implementation of many of the requirements in ISO22301.

There are no requirements to be met in this section.

3.4 Section 3: Terms and definitions

Relevant Toolkit documents:

- *None*

A total of thirty-one terms and definitions are listed within ISO22301, and these are intended to be used in preference to the equivalent definitions in ISO22300 (“Security and resilience – Vocabulary”). Many of the definitions may seem quite theoretical and of limited use but a few are worth pointing out because they help in understanding what some of the later requirements mean and how some of the documents in the Toolkit apply.

It’s worth reviewing the definitions of:

- 3.1 Activity
- 3.10 Disruption
- 3.15 Interested party/Stakeholder
- 3.31 Top management

Some of the more “technical” definitions that were in the previous version of ISO22301 have been removed from this section, with two of them mentioned as notes in the body of the text, these being Maximum tolerable period of disruption (MTPD) and Recovery time objective (RTO). The intention is to simplify the wording of the standard and hopefully make it easier to understand.

There are no requirements to be met in this section.

3.5 Section 4: Context of the organization

Relevant Toolkit documents:

- *Business Continuity Context, Requirements and Scope*
- *Legal, Regulatory and Contractual Requirements Procedure*
- *Legal, Regulatory and Contractual Requirements*

This section is about understanding of the organization itself and the environment in which it operates. The key point about the BCMS is that it should be appropriate and relevant to the specifics of the business it is protecting. To ensure this, the people implementing and running the BCMS must be reasonably knowledgeable about what the organization does, where, how and who for.

The BCMS will also be affected by the situation within the organization (internal issues) and outside the organization (external issues). Internal issues are factors such as the culture, management structure, locations, management style, financial performance, employee relations, level of training etc. that define the organization. External issues are those less under the organization's control such as the economic, social, political and legal environment that it must operate within. All of these issues (internal and external) will have bearing on the priorities, objectives, operation and maintenance of the BCMS. This is particularly relevant when we discuss the areas of business impact analysis and risk assessment where a comprehensive knowledge of how the organization operates and what could affect it are essential.

The standard also requires that all interested parties are identified, together with their requirements. This can be quite a long list of people and organizations that could be affected by a disruptive incident within your organization. As well as the obvious ones, such as customers, suppliers and employees, don't forget your neighbours, dependents of employees and trade groups. They could all be affected in different ways and have varying needs and expectations that should be considered within your BCMS.

The standard requires your organization to keep on top of legislation and regulation that control what has to be done in normal operation, and during incidents. In effect, you have to stay legal and to do that, you have to know what the law says.

The context section is also the one where the scope of the BCMS is defined. Again, this needs careful consideration. If your organization is small, it usually makes sense to place everything it does within the scope because often it can be more difficult to manage a limitation to the scope than to simply cover everything. As the organization grows in size so do the issues with scope. There are three main areas in which the scope might be limited: organization structure (e.g. one division or group company but not others), location (e.g. the Rome office but not the San Diego one) and product/service (e.g. the outsourcing/hosting service but not the software development service). It is perfectly acceptable to start with a smaller scope for certification and then widen it out year by year as the BCMS matures and everyone becomes more familiar with what's involved. In fact if you need to achieve

certification within a short timescale this may well be the best route. You must ensure however that your exclusions make sense and can be justified to the auditor.

One point to note is the difference between the scope of the BCMS and the scope of certification to the ISO22301 standard; they don't have to be the same. You can (if it's useful to do so) have a fairly wide BCMS scope but only ask for certification to a part of it initially. As long as the part in question meets all the requirements of the standard then it should be acceptable.

The Toolkit provides a template document that prompts for most of the information described above and groups the documented information required for context, requirements and scope into one place. It is perfectly acceptable to split this content into more than one document if that works better for you. A template procedure for identifying and actioning legal and regulatory requirements relevant to your organization is also included; it is important that this legal picture is kept up to date with changes to the external environment and it would make sense to consult your legal department about this, if you have one or a legal firm if you don't.

3.6 Section 5: Leadership

Relevant Toolkit documents:

- *Business Continuity Policy*
- *Roles, Responsibilities and Authorities*
- *Top Management Communication Program*
- *Executive Support Letter*
- *Meeting Minutes Template*

The leadership section of the standard is about showing that top management are serious about the BCMS and are right behind it. They may do this in a number of ways. The first is by demonstrating management commitment; partly this is by simply saying that they support the BCMS in meetings, in articles in internal and external magazines, in presentations to employees and interested parties etc. and partly by making sure the right resources and processes are in place to support the BCMS e.g. people, budget, management reviews, plans etc. Sometimes these kinds of activities can be difficult to evidence to an auditor so within the Toolkit we have provided a number of documents that may help in this, including a documented top management communication plan, an executive support letter and a template for relevant meetings to be minuted.

The second way for top management to show they are serious about business continuity is to ensure that there is a policy in place. This needs to be a physical document, signed off by top management and distributed to everyone that it might be relevant to. A template policy is provided in the Toolkit that addresses the areas required by the standard.

Lastly, top management need to make sure that everyone involved in the BCMS knows what their role(s) and associated responsibilities and authorities are. Again, a document is

provided in the Toolkit as a starting point for this. Remember to ensure that business continuity is included in the day-to-day responsibilities of existing roles rather than trying to create a parallel organization structure just for business continuity; it needs to be business as usual not an add-on.

Remember also that demonstrating leadership is an ongoing process, not a one-off activity solely during implementation.

3.7 Section 6: Planning

Relevant Toolkit documents:

- *Business Continuity Management Plan*
- *Business Continuity Policy*

This section deals with risks and opportunities for the BCMS itself, rather than those related to disruption of the business (which are addressed in clause 8.2 of the standard). These are addressed in overview in the *Business Continuity Management Plan*, but you could also use the full risk and opportunity assessment process from section 8 of the toolkit if you chose to.

Within the planning section of the standard we need to set out what the BCMS is intended to achieve and how it will be done. With regard to the BCMS there are two main levels of objectives. The first is the high-level objectives set out when defining the context of the BCMS. These tend to be quite broad and non-specific in order to describe why the BCMS is necessary in the first place and these objectives probably won't change much.

The second level of objectives is more action-oriented and will refer to a fixed timeframe. In the Toolkit we have provided a *Business Continuity Management Plan* for a financial year on the assumption that a one-year planning horizon will be used, but this could be a two- or three-year plan if that makes sense in your organization. The *Business Continuity Management Plan* sets out specific objectives, including how success will be measured, the timeframe and who is responsible for getting it done. You may choose to create a Gantt chart plan in MS Project or similar to support this.

The issue of planning changes to the BCMS is addressed within the *Business Continuity Policy* which requires top management to ensure that effective control is exercised.

3.8 Section 7: Support

Relevant Toolkit documents:

- *Procedure for the Control of Documented Information*
- *BCMS Documentation Log*

- *Competence Development Procedure*
- *Competence Development Report*
- *Competence Development Questionnaire*
- *Business Continuity Communication Plan*
- *Business Continuity Awareness Presentation*

Covering resources, competence, awareness, communication and documented information, this section describes some of the background areas that need to be in place for the BCMS to function properly.

The Toolkit provides a method of conducting a survey of the people involved in the implementation and running of the BCMS, collating the results and then reporting on those areas in which further training or knowledge needs to be gained. You will need to ensure that appropriate records of training are kept and are available to view by the auditor.

A template business continuity awareness presentation is also provided. This may be delivered in various ways, including at specially arranged events or at regular team meetings, depending on the timescale required and the opportunities available. Note that the focus of this is awareness rather than detailed training and that anyone with a more involved role to play in the BCMS may need more in-depth training.

Communication procedures during an incident are covered in the Toolkit document *Business Continuity Plan* but if you have specific procedures relating to business-as-usual communication with internal and external parties, they may be relevant to this section of the standard and a template document *Business Continuity Communication Plan* is provided in the Toolkit.

Documented information required by the standard must be controlled which basically means keeping it secure, managing changes to it and ensuring that those that need it have access to it. A procedure that covers the requirements for document control is provided and you will need to decide where such documentation is to be held. In modern times this is usually electronically and could be on a shared network drive, an intranet, a full-blown document management system or any other arrangement that is appropriate to your organization.

3.9 Section 8: Operation

Relevant Toolkit documents:

- *Business Impact Analysis Tool*
- *Business Impact Analysis Report*
- *Risk Assessment and Treatment Process*
- *Risk Assessment Report*
- *Risk Treatment Plan*
- *Business Continuity Strategies and Solutions*

- *Business Impact Analysis Process*
- *Business Continuity Plan*
- *Supplier BC Evaluation Process*
- *Business Continuity Exercise Programme*
- *Business Continuity Test Plan*
- *Business Continuity Test Report*
- *Standard Operating Procedure*
- *Continuity Operating Procedure*
- *Post Incident Report*
- *Business Continuity Procedure*
- *Risk and Opportunity Assessment and Treatment (ROAT) Tool*
- *Business Continuity Contact Log*
- *Incident Impact Information Log*
- *Plan Activation Log*
- *Incident Response Action Log*
- *Message Log*
- *Internal Contact List*
- *External Contact List*
- *Business Continuity Procedure Evaluation Checklist*

The operation section of the ISO22301 standard is where the majority of the activities and requirements normally associated with business continuity are defined. The main areas covered are business impact analysis (BIA), risk assessment, business continuity strategies and solutions and business continuity procedures (including business continuity plans).

The business impact analysis is conducted first to identify the effects on the organization and its interested parties of not being able to carry out the normal functions of the business (e.g. loss of revenue, reputation etc.). This is then used as input to a risk assessment which takes into account the likelihood of various threats that have been identified (e.g. fire, flood etc.). In essence, a combination of a medium to high likelihood and a medium to high impact means that something needs to be done either to lessen the risk or plan for it.

Based on the risk assessment a business continuity strategy (or set of strategies) and a set of accompanying solutions is designed to address those areas of greatest concern. The strategies are then implemented as a set of business continuity procedures and plans which make use of one or more of the individual solutions. Lastly, these procedures and plans need to be tested to verify that they work.

It's worth giving an example here to try to clarify the relationship between a strategy, solution, plan and procedure.

Based on your business impact analysis and risk assessment, you may decide that the risk of flooding of your main building is something you need to plan for. So you decide that the **strategy** you will adopt is to relocate to an alternative site if the worst happens. In order to achieve this strategy you may need a **solution** for emergency transport (to get people and other resources to the alternate site), a **solution** for network redirection (so that people working at the alternate site have access to IT systems) and a **solution** for alternate staffing

(to ensure those areas of the business that are most important have enough people to support them). So that's one strategy that makes use of three solutions to achieve it.

There will then be a **plan** which will set out how a flooding event will be responded to. There may be more than one strategy available to cope with this type of incident, so a choice between strategies may need to be made. If you choose the alternate site strategy, then a set of **procedures** will be invoked to deliver the solutions that make up that strategy. These will define how to arrange emergency transport, how to redirect the network and how to find more staff. The idea is to create a flexible framework where strategies and solutions may be selected dynamically based on the circumstances, given that what actually happens is rarely what was planned for.

So there is a fairly well-defined order in which these activities need to be conducted and this order is set out in the standard.

3.9.1 Business impact analysis

The Toolkit provides a business impact analysis tool which prompts for the main items of information to be identified and recorded. The first is to list the main business activities of the organization together with their purpose, resources dedicated and legal constraints (tool tab Key business activities). For a large organization there may be very many activities and the BIA may need to be split into more manageable parts in order to cover the whole company. There may already be a centralized list of business activities in existence within the organization in which case it makes sense to use that (as long as it is reasonably current). Focus on those activities that are generally regarded as the most important ones first as this will give you a head start. There may be some less well-known activities that turn out to be important, but this is relatively rare, so concentrate your efforts on the areas of greatest reward at least initially.

After listing the key business activities, you then need to assess the impact of each one not happening (tool tab Impact of Disruption). Impact can be in different areas such as finance (loss of revenue, cashflow etc.), customers (they may be unable to run their businesses if you don't provide this activity, or end users may be affected sometimes significantly depending on the products and services you provide) or reputation (will customers or clients come back after you have rectified the problem?). The other factor is how quickly these impacts are felt; some activities might have a gradual impact if they are not delivered whereas for others the effect could be immediate. Use the tool to set out, for each activity in turn, how the impact builds in each area over time to give an overall impact rating (total score).

On the next tool tab, Key Targets, this analysis will then give you an indication of two important factors used in business continuity:

- Maximum Tolerable Period of Disruption (MTPD) – how long before the impact becomes unacceptable to the organization

- Recovery Time Objective (RTO) – the target time to recover the activity to at least partial operation

The RTO may be the same as the MTPD but often it makes sense to make it a shorter time to allow for delays in recovery. On this worksheet we also need to assess how much of the activity you need to provide as a minimum e.g. the level of degraded service. This is referred to by the ISO22301 standard as the Minimum Business Continuity Objective, or MBCO. The last key target, the Recovery Point Objective (RPO), is particularly relevant to IT systems where data needs to be recovered to a specific time before the failure occurred (e.g. no more than one hour before). All of these factors are important when we start to consider business continuity strategies and plans to meet them and the cost of achieving that.

We also need to assess and document what resources are needed across the board to recover each activity over time. Otherwise we may find we don't have enough desks or computers or space etc. to recover everything according to the plan. The recovery process may need to happen gradually and so resources may be added at key points. The idea is to work out how much of each resource will you need and when in order to meet your minimum business continuity objective (MBCO) for each activity. The total of these will tell you about your overall requirement for planning purposes.

At the end of the BIA we should have a clear understanding of what is needed for recovery purposes and when, based on a solid understanding of the organization.

3.9.2 Risk assessment

Having established the impact to the organization of not being able to deliver its key activities, a risk assessment now needs to be conducted to analyse and evaluate the likelihood of various events occurring. This will then give you the opportunity to do something about those risks that are both likely and have a significant impact i.e. to treat the risks. The ISO22301 standard encourages you to become proactive in preventing incidents from happening in the first place; obviously if they still do then you will have a plan in place to manage the impact and ensure business continuity.

There are many ways of analysing risk and the ISO22301 standard suggests that another standard, ISO 31000, could be used as a framework for this. ISO31000 is worth a read and sets out how to establish an organization-wide framework for risk assessment, not just for business continuity purposes but for all potential risks to the business. But ISO31000 itself doesn't go into detail about how risks should be identified; there is yet another standard that does, which is ISO31010. You may realise from this that risk assessment is a very big subject in itself and there are very many techniques available to use if you choose to; ISO22301 doesn't dictate which one to use and our recommendation is that you keep it as simple as possible, depending on the size of your organization and how much time you have.

The Toolkit provides a risk assessment and treatment process which is compatible with the ISO31000 standard. Effective risk identification can often be done by simply getting the right

people with the relevant knowledge into a room and asking them about what they worry about most with regard to their area of responsibility. This should give you a good starting point to assess the risks that they identify. Consult other parties such as external consultants and authorities where appropriate to get as good a picture as possible.

The identified risks may be entered into the *Risk and Opportunity Assessment and Treatment (ROAT) Tool* which helps you to assess the likelihood and impact of each risk, giving a risk score. The workbook uses a defined classification scheme to label each risk as high, medium or low risk, depending on its score. A template *Risk Assessment Report* is provided in the Toolkit to communicate the findings of the risk assessment to top management and so that they can sign it off.

Whether or not each risk needs to be treated depends upon your risk appetite i.e. how much risk you are willing to accept. For those risks that do need treatment there are three main options:

1. Mitigate: Take some action to reduce the likelihood or impact of the risk
2. Avoid: Top performing the activity that gives rise to the risk
3. Transfer: Get another party to assume the risk (e.g. insurance)

Each of these options will have some effect on either the likelihood or impact of the risk, or both. The *Risk and Opportunity Assessment and Treatment Tool* allows you to define what effect you believe the treatment will have in order to decide whether it is sufficient.

Once the risks have been identified, assessed and evaluated, the risk treatment plan is created. Again the Toolkit has a template plan which may be used to obtain top management approval of the recommended risk treatments, some of which may involve spending money. Top management also need to agree to the levels of residual risk after the treatments have been implemented (i.e. the risks we're left with once we've done everything proposed).

The key point to remember in treating risk is that it is a trade-off. Few organizations have limitless funds and so the money spent in treating risk needs to result in a larger benefit than the cost. There are many ways of performing this kind of "quantitative" analysis so that the potential loss from a risk can be expressed in financial terms. The method used in the Toolkit is "qualitative" in that it simply categorizes the risks; if your organization wishes to use more detailed quantitative methods to assess risk loss against cost of treatment then that is perfectly acceptable within the ISO22301 standard.

3.9.3 Business continuity strategies and solutions

Having identified what the impacts of not being able to deliver key business activities are (including the MTPD, RTO, RPO and MBCO) and determined the greatest areas of risk (and taken actions to address them) we now need to decide what approach will be taken to resuming business activities within the time required. The ISO22301 standard defines this

approach as a strategy and the best one (or more) to adopt will of course depend upon how many resources (e.g. money) we have available to achieve it.

The business impact analysis will have provided a clear idea of what the organization stands to lose if it can't recover its activities within their RTO and this, together with the risk assessment, gives us an idea of the appropriate budget (remember however that the appropriate budget depends not only on the potential loss but also how often that loss might happen).

Using an IT example, possible strategies might vary from a cold site recovery, where only the building is available, through to a hot site facility where all of the hardware, software and data is always available at a moment's notice. The costs at these two extremes will be very different and ideally it should be the RTO that determines which is the best strategy to adopt.

The Toolkit includes a document *Business Continuity Strategies and Solutions* which guides you through the consideration of the pros and cons of alternative approaches. A different strategy may be needed for different business activities e.g. if they are located at facilities in multiple countries.

Each strategy will be implemented via one or more solutions, which are effectively a collection of procedures which achieve each of the building blocks in the overall strategy. But these solutions may be relevant to achieving other strategies too, so they exist in their own right as available options depending on the circumstances.

The standard also requires that you evaluate the business continuity capabilities of suppliers; a document for this purpose, *Supplier BC Evaluation Process*, can be found in the Toolkit. The degree to which you do this should depend upon the importance of the supplier to the key business activities you have identified.

3.9.4 Business continuity plans and procedures

Each strategy will be implemented using one or more business continuity procedures which set out who will do what, where and when and the Toolkit provides a template for such procedures, supplemented by examples, including one for a loss of a building and one for a pandemic.

However, the standard also requires that procedures are in place in the areas of:

- Incident response structure
- Warning and communication

Within the Toolkit, these requirements are included within the document *Business Continuity Plan* which details how an incident will be managed and how communications will be achieved. This supported by a number of forms, which are used to record contact lists and things like decisions made and actions taken during an incident.

A *Standard Operating Procedure* template is provided as a starting point for the definition of more detailed, low-level procedures which may be required to set out how the business continuity solutions are implemented. This is further expanded via the use of a *Continuity Operating Procedure* where necessary.

3.9.5 Exercise programme

In this section of the ISO22301 standard, it is required that the business continuity procedures are exercised and tested to make sure they deliver the intended results. There are several ways of conducting exercises and tests, ranging from desktop run-throughs to full blown simulations. The important thing with respect to the standard is that you plan them, you document them (before and after) and that they cover all of the plans within a reasonable timeframe (this timeframe is not defined in the standard). We provide a test programme, plan and report within the Toolkit for your use.

3.9.6 Evaluation of business continuity documentation and capabilities

There is also a requirement to regularly evaluate your business continuity procedures to ensure that they stay up to date and appropriate. This can be done in a number of ways, including internal audits and management reviews, but it can be helpful to regularly review specific procedures at a local level. A checklist is provided in the Toolkit to help with this process.

3.10 Section 9: Performance evaluation

Relevant Toolkit documents:

- *Procedure for Internal Audits*
- *Procedure for Management Reviews*
- *Management Review Meeting Agenda*
- *Internal Audit Action Plan*
- *Process for Monitoring, Measurement, Analysis and Evaluation*
- *Internal Audit Schedule*
- *Internal Audit Action Plan*
- *Internal Audit Checklist*
- *Internal Audit Report*

The performance evaluation section of the standard is about how you determine whether the BCMS is doing what it is supposed to do.

3.10.1 Monitoring, measurement, analysis and evaluation

The ISO22301 standard does not tell you what you should measure. It simply requires that you be precise about what it is you have decided to measure and that you do something about it if your measurements show some kind of problem. The auditor will expect you to have put some thought into the appropriate measurements to take, how they can be taken and how the results can be reasonably interpreted. The Toolkit provides a document entitled *Process for Monitoring, Measurement, Analysis and Evaluation* which includes suggestions for the types of measurements that might be suitable for a typical organization, but you will need to look at these carefully before using them. It's a good idea to create a documented procedure for the collection and reporting of each measurement because if it is done differently each time then the results will not be helpful.

This is an area that can start relatively small and expand over time; our recommendation is that you select some basic measurements that are easy to collect and interpret and use those for a while. After some time has passed it will probably become obvious that other specific measurements are needed to be able to assess whether things are going well so these can be added gradually. Be careful not to start with a wide range of possibly meaningless, hard to collect measurements that will simply slow everything down and give the BCMS a bad reputation before it has got going.

Having chosen your measurements you need to decide what does "good" look like; what numerical values would mean that performance is in line with expectations? Again, the definition of your objectives may need tweaking over time as you gain experience with taking the measurements and your BCMS moves from implementation mode into ongoing operation mode.

If you find that your objectives are not being met, then an improvement may be required to bring the situation back into line; such improvements should be recorded and tracked through to completion.

3.10.2 Internal audit

The standard requires that there is an internal auditing programme in place which audits all aspects of the BCMS within a reasonable period of time. If you embrace the idea of internal auditing as a useful early warning of any issues at external audit, then you won't go far wrong. Internal audits should ensure that there are no surprises during the annual certification/surveillance audit which should allow everyone a higher degree of confidence in the BCMS.

In terms of where to start auditing, the standard suggests that you consider the importance of the processes concerned, problem areas identified in previous audits and those parts of the BCMS where significant risks have been identified. Beyond that, there is no particular order in which internal audits need to happen. Auditors need to be suitably qualified either through experience or training (or both) and must be impartial i.e. they are not involved in the setting up or running of the BCMS.

The Toolkit has a number of documents to help with the internal auditing process, including a schedule, plan, procedure and post-audit action plan. In general, all aspects of internal auditing need to be documented and an external auditor will almost always want to see the most recent internal audit report and track through any actions arising from it.

3.10.3 Management review

Management review is another key part of the BCMS which, if you get it right, will hold together everything else and make audits (internal and external) a relatively straightforward experience. The ISO22301 standard is pretty specific about what these reviews should cover but it is less forthcoming about how often they should take place. This is one of those areas where you will need to try it and see what works for your organization; too often and it becomes an unacceptable administrative overhead; too infrequent and you risk losing control of your BCMS. The generally accepted minimum frequency is probably once a year and, in this case, it would need to be a full review covering everything required by the standard. A more common approach is to split the management review into two parts: perhaps a quarterly review of the main areas with a more complete review on an annual basis. You may even decide that in the early days of the BCMS a monthly review is appropriate. There is no wrong answer, there's just a decision about how much control you feel you need to exercise at management level.

In all cases, every management review must be minuted and the resulting actions tracked through to completion, usually via the BCMS continual improvement action log. The Toolkit has a sample agenda for a management review and a procedure covering the process.

3.11 Section 10: Improvement

Relevant Toolkit documents:

- *Nonconformity and Corrective Action Log*
- *Procedure for the Management of Nonconformity*

Despite the section heading of “Improvement”, this section of the standard talks mostly about non-conformities and corrective actions. The ISO definition of a non-conformity is the rather general “non-fulfilment of a requirement” and since a requirement can be pretty much anything, it is best to bring any actions, requests, ideas etc. together in a single place and manage them from there. The Toolkit provides the *Nonconformity and Corrective Action Log* for this purpose. A procedure is also provided which explains how items are added to the list, evaluated and then tracked through to completion.

4 Advice for the audit

4.1 Choosing an auditor

If your organization wishes to become certified to the ISO22301 standard, it will need to undergo a two-stage process performed by a suitable external auditing body. Before this, you will need to select your auditing body and, in most countries, there are a variety of options. If you are already certified to a different international standard such as ISO 9001 then it usually makes sense to use the same auditing company for ISO22301, as long as they can provide that service. Increasingly, multi-standard audits will become commonplace as the effects of the Annex SL revisions are felt (see section 1.1 The ISO22301 standard).

There are many companies that offer certification audits, and your choice will obviously depend upon a variety of factors including where in the world you are based. However, there are a few general things you need to be aware of before you sign up with any particular auditor.

4.1.1 Self-certification

The first is to emphasize the fact that ISO standards are not legal documents; the creation, maintenance and adoption of ISO standards is a voluntary exercise that is co-ordinated by the ISO. Yes, ISO owns the copyright and sells standards for cash both directly and through third parties, but rest assured that you won't be breaking any laws if you don't quite implement a standard in full. And the same goes for declaring compliance with ISO standards. You have a choice.

You could simply tell everyone you deal with that you meet the requirements of a particular ISO standard. That's it – no audit fees or uncomfortable visits from men in suits. Just say that you comply. The trouble with this is that if everyone did it, there would be no way of telling the difference between good organizations that really had done it properly and less conscientious ones that just paid the standard lip service. It only takes a few bad apples to spoil it for everybody. The people that matter to you (for example, your customers or regulators) may simply not believe you.

4.1.2 Third-party certification

So instead you may decide to get a third party to test your implementation of a standard and testify that you've done it properly. This is where Registered Certification Bodies (RCBs) come in. An RCB is a company that has the expertise and resources to check that you do indeed meet the requirements of the standard and is willing to tell others that you do. But hold on, how do your customers know that the RCB itself can be trusted to have done a good job of the audit?

What's needed is another organization that is trusted to check the auditors and make sure that they are doing a good job. But how do we know they can be trusted? And so it goes on. What we end up with is a chain of trust similar to the way that Public Key Infrastructure works. At this point we need to introduce you to a few important definitions:

Certification: What happens when you are audited against a standard and you (hopefully) end up with a certificate to put on the wall (as in "we are certified to ISO22301").

RCB: A Registered Certification Body is basically an auditing company that has been accredited to carry out certification audits and issue a certificate to say you are compliant with a particular standard. Some operate in a single country and some in a lot of countries. This is what you, as an organization wanting to become certified, need to choose.

Accreditation: What the auditors go through to become an RCB and allow them to carry out certification audits.

Now we've got those definitions out of the way we need to talk about who actually does the accrediting. There are basically two levels, international and national.

IAF: Based in Quebec, Canada, the International Accreditation Forum is the worldwide body that represents the highest level of trust concerning accreditation of RCBs. They have lots of strict rules that national accreditation bodies must agree to, embodied in a charter and a code of conduct. All of the national accreditation bodies are members of the IAF.

ANAB: As if there weren't enough acronyms in the world, here we have an acronym within an acronym. ANAB stands for the ANSI-ASQ National Accreditation Board. ANSI is the American National Standards Institute and deals with standards in the USA. ASQ is the American Society for Quality and although based in the USA, has a more international reach than ANSI. So put them together and you get ANAB which is the national accreditation body for the USA and therefore a member of the IAF.

UKAS: The United Kingdom Accreditation Service is the body in the United Kingdom that accredits RCBs. It is effectively the UK representative of the IAF.

JAS-ANZ: The Joint Accreditation Service of Australia and New Zealand is the IAF member for these countries.

DAC: The Dubai Accreditation Department is a government department that accredits RCBs within the United Arab Emirates.

4.1.3 Other IAF members

There are over 60 other members of the IAF which provide accreditation services for their respective countries and a full list can be found on the IAF website so when you have a moment why not look up the member organization for your country.

The core message here is that whichever RCB you choose to carry out your certification audit, make sure they are accredited by the IAF member for your country. So for the UK that means UKAS-accredited, the USA ANAB-accredited and so on. Most auditing companies display the logo of the organization that they are accredited by fairly prominently on their website so it should be easy to tell.

4.1.4 Choosing between accredited RCBs

So you've checked that the audit companies you're considering are accredited, but what other factors come into play when making your decision? In our experience asking the following questions will help you to choose:

- **Which standards do they audit?** Check the RCB has the capability to audit the standard you are going for and if so, how many customers they have for that standard. How long have they been auditing the standard and how many qualified people do they have?
- **Do they cover the geographical areas you need?** There's no point in considering an RCB that can't cover the geographical area(s) you need. This is particularly relevant if you need to have more than one office audited, possibly in different countries. They may cover one country but not another. It's worth checking whether they feel an onsite visit is needed to all of the offices in scope before you dismiss them.
- **How long will it take?** Officially, there is a formula that should be used when calculating how many days an audit should take. This takes into account variables such as number of locations and employees and which standards are involved. However, there is some flexibility in how the formula is applied so you may get differing estimates from RCBs on how many days will be needed, which will obviously affect the cost.
- **How much will it cost?** This follows on from the question about time as most RCBs charge by the hour or day, but rates can vary significantly so a longer audit could actually be cheaper. Take into account the ongoing certification fees as well as the cost for the stage one and stage two audits.
- **What is their availability?** Auditors are generally busy people so if you're in a hurry to get your organization certified then their availability will be an important factor. How soon can they do a stage one and when can they come back for the stage two?
- **What is their reputation?** Even amongst accredited RCBs, there are more and less well-known names. Since a lot of the reason for going for certification is to gain credibility with your customers and perhaps regulators, consider which RCB would carry most weight with them.
- **How good is their administration?** A lot of the frustration we see with RCBs is not due to the quality of their auditors but their administration processes. You need an auditing company that will arrange the audits professionally and issue your certificate promptly, providing additional materials to help you advertise your certification. When you contact them initially, do they return your call and sound knowledgeable?

- **Do they use contract auditors?** Many RCBs use auditors that are not directly employed by them, which is not necessarily a problem, but it would be useful to understand how much continuity you will have with the individuals that carry out your audits. Try to avoid having to describe what your company does to a new auditor every visit as this soaks up time that you are paying for.
- **Do they have experience of your industry?** Some RCBs and auditors specialize in particular industries and build up a strong knowledge of the issues relevant to their customers. This can be helpful during the audit as basic industry concepts and terms will be understood and time will be saved. Check whether they have audited similar organizations in your industry.

Making a good choice based on the above factors can't guarantee that the certification process will run smoothly, but by having a good understanding of the accreditation regime and by asking the right questions early on you will have given yourself the best chance possible to have a long and happy audit relationship.

Having agreed a price, your chosen external auditor will contact you to arrange the Stage One review. This is essentially a documentation review and a "getting to know you" discussion where the exact scope of potential certification is decided. Based on the Stage One, the external auditor will make a recommendation about your readiness for the Stage Two – the certification audit itself. It used to be common for there to be at least a three-month gap between the Stage One and the Stage Two visits, but this is less often the case nowadays and the two can be quite close together if desired.

4.2 Are we ready for the audit?

Deciding when to ask the external auditor in for the Stage One visit is a matter of judgement on your part. If you invite them in too early, they will simply tell you you're not ready and this can have a detrimental effect on team morale (and possibly cost you more money for further visits). If you leave it longer the danger is that you're extending the timescale to certification unnecessarily. We suggest you use the *ISO22301 Gap Assessment Tool* within the Toolkit as a guide to your readiness, but don't expect to be 100% compliant before going for Stage One. A more appropriate figure is probably 90% or so but it does depend on which areas are not yet complete.

Before arranging the Stage One you should definitely have completed the following:

- Business continuity policy
- Business impact analysis
- Risk assessment and treatment plan
- Business continuity strategy and procedures
- At least one business continuity exercise or test
- Internal audits of all areas of the standard
- At least one management review (ideally more)

Not having any of the above available would probably mean that the Stage One visit is inconclusive in terms of judging your readiness for the Stage Two i.e. the auditor would tell you just weren't ready yet.

4.3 Preparing for audit day

Once you feel you're ready to be visited by the auditor for either the Stage One or Stage Two then there are a number of sensible preparations to take to make the best impression from the start. Firstly, make sure that the visit is confirmed, provide directions and check the time of arrival of the auditor(s). If appropriate, inform reception that he/she will be coming, get an identity badge prepared and reserve a parking space. Book a room for the auditor's use (more if there is a team) and ensure that refreshments will be available, including lunch if possible. You will be needing to show documents and discuss them, so some form of large screen or projector will be useful.

Once the basic arrangements are in place you need to ensure that whoever is going to act as the auditor's guide around the BCMS is ready. This means knowing where all of the relevant documents are and how each of the requirements is met within the documents. Supporting information such as HR and training records should also be available if required. Anyone who might be able to help the auditor such as local BC co-ordinators should be on standby and everyone who is planned to talk to the auditor should be prepared.

There is no substitute for practice so conduct a mock audit beforehand if you can and identify any improvements needed before the day. Having obvious signs of BC activity on display at your location does no harm; this could be performance charts or posters for raising awareness on the walls.

It's all about showing the auditor that you are a professional organization that is in control; you may be surprised how little the auditor feels he needs to look at if the overall impression he's getting is very positive.

4.4 At the audit

The auditor should have provided an audit plan which will set out the structure of the audit, including areas to be reviewed, people to be met and timings (this often doesn't happen so don't worry if you don't get one). Despite the appearance of power, auditing is actually quite strictly regulated so the auditor will have specific things he needs to do, in a specific format, starting with an opening meeting and ending with a closing meeting. Do what you can to make it easy for him by providing access to the relevant documents and resources as quickly and smoothly as possible.

Basically, all the auditor is doing is the same exercise as you did yourself when you performed (and repeated) the gap assessment. It's purely a matter of going through the requirements of the ISO 22301 standard and asking to be shown how you meet them. The

auditor will need to record the evidence he has been shown, including any relevant references such as document titles and versions. He may also want to see the relevant procedures etc. in action which may mean reviewing the records you keep and possibly talking to the people who perform the procedures.

If the auditor finds something that doesn't conform to the requirements of the standard, he will raise a "non-conformity". These can be major or minor and, as the names suggest, these vary in importance.

A major non-conformity may be raised if there is a significant deviation from the standard. This is often due to a complete section not really having been addressed, or something important that has been documented but there is no evidence that it has been done. Examples might be if no internal auditing has been carried out, no risk assessment done, or no management reviews held.

A minor non-conformity is a lower-level issue that doesn't affect the operation of the BCMS as a whole but means that one or more requirements have not been met. Examples could be that an improvement has not been evaluated properly, a test has not been carried out as planned or a risk assessment doesn't follow the documented process.

Some auditors take note of a third level of item often called an "observation". These are not non-conformities and so don't affect the result of the audit but may be useful for improvement purposes.

Once the audit has been completed the auditor will write up the report, often whilst still on site. He will then tell you the result of the audit and go through any non-conformities that have been raised. Certification to the standard is conditional upon any non-conformities being addressed and upon the higher-level body that regulates the auditors agreeing with his recommendations. This can take a while to process so, even if you have no non-conformities, officially your organization is not certified yet.

You will need to produce an action plan to address the non-conformities and if this is accepted and they are closed off, you will then become certified, and the certificate will be issued for a period of three years. During this time, there will be annual surveillance visits followed at the three-year mark by a recertification audit.

4.5 After the audit

There is usually a huge amount of pressure built up before the audit and once it's over the relief can be enormous. It's very easy to regard the implementation of a BCMS as a one-off project that is now over. But the auditor will be back within the next twelve months to check that you have carried on running the BCMS as required, so you can't afford to relax too much.

Certification is really a starting point rather than an end result and hopefully as time goes by your BCMS will mature and improve and start to provide more and more value to the

organization. However you may find that the resources that were made available for the implementation now start to disappear, and you need to ensure that the essential processes of the BCMS are maintained. Plans can get out of date very quickly so the performance evaluation side of the BCMS in particular will become very important; make sure you continue with the management reviews, exercising and testing programme and internal audits and this should drive the rest of the BCMS to stay up to date.

5 Conclusion

This implementation guide has taken you through the process of putting a BCMS in place for your organization, supported by the CertiKit ISO22301 Toolkit. Hopefully you will have seen that most of what's involved is applied common sense, even if the standard doesn't always make it sound that way!

Implementing a management system such as ISO22301 is always a culture change towards becoming more proactive as an organization and, with the day-to-day reactive pressures of delivering a product or service, it can sometimes seem daunting. However, we hope you will find that it's well worth the effort as you come to the gradual realization that it's really the only effective way of doing it.

We wish you good luck in your work and, as always, we welcome any feedback you wish to give us via feedback@certikit.com.